Hệ Thống Lý Dự Án Đầu Tư Công thiết kế cơ bản

(Cập nhật 1.4 — CR-04-01) Baseline 1.4 | 22/10/2026 | Đối tượng: kiến trúc sư, kỹ thuật trưởng, AI agent viết code, vận hành và an toàn thông tin.

(Cập nhật 1.4 — CR-04-02) Vị trí của tài liệu:

Đây là tài liệu kiến trúc có thẩm quyền của baseline 1.4. Khi đặc tả phân hệ (`05_modules/<MÃ>.md`), `05_Thiet_ke_chi_tiet.md` hoặc tài liệu HTML trong `03_Engineering` mâu thuẫn với tài liệu này về tenant, ranh giới module, stack, RLS, đồng bộ, điều phối, tích hợp, hosting hoặc vận hành, tài liệu này thắng và mâu thuẫn được ghi thành CR. Đặc tả phân hệ là nguồn cho chi tiết nghiệp vụ (state machine, công thức, API, bảng). Yêu cầu phi chức năng đo được nằm ở `03_Engineering/nonfunctional_requirements.json` (ID `NFR-<AREA>-NN`), mỗi NFR có cơ chế kiểm soát và test `UAT-NFR-*`.

Căn cứ: Decision register D-B01…D-B12, kiến trúc K1–K9, decision ledger R1–R11 và bằng chứng bắt buộc A1, A3, P1–P3 của plan đã duyệt ngày 22/10/2026; nghiên cứu nguồn tại `01_Nghien_cuu_va_phan_tich_nguon.md`. Mục đánh dấu [GIẢ ĐỊNH] là lựa chọn của Claude theo D-B04 chờ đo hoặc chốt; nhãn CXN-<mã> là căn cứ pháp lý chờ xác nhận (R4).

Cách đọc bản 1.4: tài liệu giữ nguyên chín mục của baseline 1.3. Đoạn baseline còn đúng được giữ nguyên văn; đoạn sửa hoặc thêm mang nhãn "(Cập nhật 1.4 — CR-04-nn)". Đoạn baseline bị sửa hoặc bỏ được chép nguyên văn ở "Phụ lục: ánh xạ nội dung baseline 1.3" cuối tài liệu, kèm nơi nội dung đó hiện nằm.

Kiến trúc mục tiêu

(Cập nhật 1.4 — CR-04-03) Phân tách control plane và tenant data plane. Control plane (phân hệ SAS, vai trò System Admin) quản lý tenant, placement, domain, gói, subscription, license, entitlement, thương hiệu, cấu hình vùng và health. Tenant data plane xử lý dự án, kế hoạch, vốn, báo cáo, văn bản, hồ sơ, thanh toán, vướng mắc, hội thoại và BI. Web/mobile chỉ gọi API/BFF; không truy cập trực tiếp DB, vault hay provider API bằng khóa dài hạn.

(Cập nhật 1.4 — CR-04-04) Đã chốt (K1, D-B07) modular monolith cho toàn bộ giao dịch nghiệp vụ, với ranh giới module rõ theo bản đồ 25 phân hệ + platform kernel bên dưới. Worker document/OCR, AI gateway, notification và analytics chạy thành process riêng do tải và vòng đời khác, nhưng cùng mã nguồn. Modular monolith là một artefact triển khai: một image API cộng các process worker `api`, `outbox-relay`, `temporal-worker`, `projection-worker`, `ai-worker`. Chưa cần chia mọi CRUD thành microservice. Dùng event/outbox để dễ tách module khi tải và đội vận hành thực sự đòi hỏi. Tách thành service riêng chỉ khi có số đo tải hoặc vòng đời khác biệt được ghi CR; giao tiếp giữa module đã là interface + event nên không đổi hợp đồng khi tách. Quyết định này giảm giao dịch phân tán trong kiểm soát số dư và phiên bản.

(Cập nhật 1.4 — CR-04-05) Luồng logic: Web (React) / App (Flutter) → WAF + reverse proxy → API NestJS (xác thực OIDC Keycloak → tenant resolver từ membership → policy/entitlement → command hoặc query handler của module) → PostgreSQL (RLS) + outbox + object storage. Outbox relay → consumer nội bộ (projection BI, notification, tích hợp, AI job) và Temporal (luồng dài). Ở R0–R1 không có broker riêng; outbox relay + inbox thay vai trò broker (xem Stack). AI worker → truy xuất theo ACL → LiteLLM (định tuyến theo phân loại) → model được duyệt. Tệp từ hệ thống ngoài → cổng import → kiểm hash/khóa nghiệp vụ → quarantine/staging → command domain. Callback provider → webhook gateway (xác thực chữ ký) → inbox dedupe → worker → command domain.

Bản đồ module (Cập nhật 1.4 — CR-04-06)

25 phân hệ nghiệp vụ (18 có từ baseline 1.3 + 7 mới DOC, LND, PMT, QMS, AUD, AST, MNE) cộng platform kernel. Mỗi module là một NestJS module có thư mục `modules/<code>/{domain,application,infrastructure,api}`; chỉ `application/public` (interface + DTO) và sự kiện được module khác dùng. Bảng thuộc về đúng một module; module khác không đọc/ghi trực tiếp bảng đó (ngoại lệ: projection BI đọc qua read model được công bố).

Mã	Tên	Lớp	Aggregate sở hữu chính	Gọi đồng bộ (interface)	Nhận sự kiện từ
kernel	Platform kernel	L0	TenantContext, AuditEntry, OutboxEvent, InboxRecord, IdempotencyRecord, FileObject, RuleVersion (legal_basis), ProblemCode	—	—
SAS	SaaS và tenant (control plane)	L1	Tenant, Placement, Plan, Subscription, EntitlementOverride, UsageCounter, License, ThemeVersion	kernel	LLM, NOT (usage)
IAM	Truy cập và cá nhân	L1	UserAccount, Session, MfaFactor, ConsentRecord, PersonalPreference	SAS	ADM (grant đổi)
LLM	Quản trị AI và LLM	L1	ModelRegistry, AiProfile, PromptVersion, AiBudget, AiRequest, EvalRun	SAS	—
ADM	Quản trị tenant	L1	OrganizationUnit, Membership, RoleGrant, Delegation, WorkflowVersion, DoAMatrix	IAM, SAS	—
MDM	Master data	L1	MasterRecord (đơn vị, nguồn vốn, chương trình, nhà thầu, danh mục), Crosswalk, MergeEvent	ADM	DGV (DQ incident)

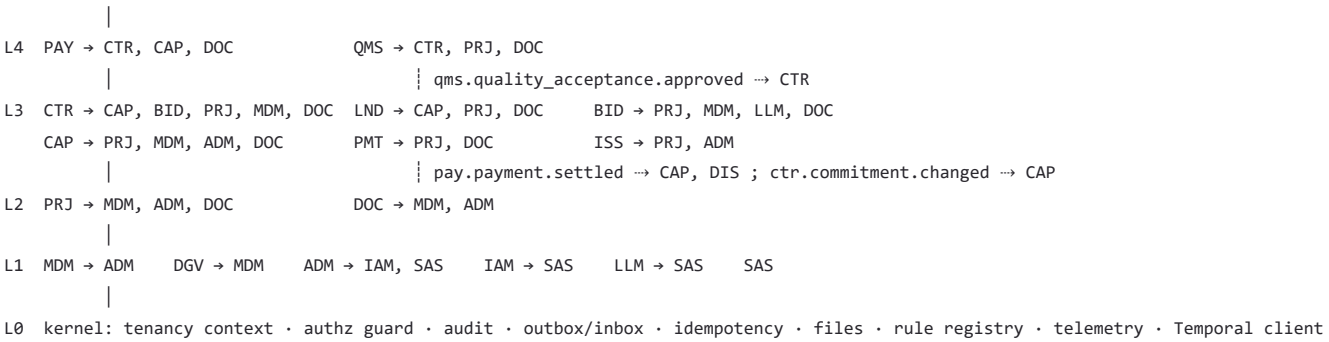
Mã	Tên	Lớp	Aggregate sở hữu chính	Gọi đồng bộ (interface)	Nhận sự kiện từ
DGV	Quản trị và trưởng thành dữ liệu	L1	DataContract, DqRule, DqResult, DqIncident, GlossaryTerm, MaturityAssessment	MDM	mọi module (metadata, DQ)
DOC	Văn bản & báo cáo theo chuẩn nhà nước	L2	DocumentTemplate, DocumentNumberRegister, OutgoingDocument, IncomingDocument, Dossier, RetentionPolicy, SignatureVerification	ADM, MDM	—
PRJ	Danh mục dự án	L2	Project, ProjectComponent, AppraisalScore, ProjectAssignment, RiskItem	MDM, ADM, DOC	CAP, PAY, ISS (trạng thái)
CAP	Kế hoạch và nguồn vốn	L3	FundSource, Appropriation, PlanVersion, AllocationLine, Earmark, TransferProposal, DisbursementPlan	PRJ, MDM, ADM, DOC	PAY (đã thanh toán), CTR (cam kết)
PMT	Hồ sơ pháp lý & giấy phép	L3	PermitDossier, Permit, PermitMilestone	PRJ, DOC	—
ISS	Vướng mắc và hiện trường	L3	Issue, IssueAssignment, Resolution, FieldVisit	PRJ, ADM	LND, PMT, QMS (tạo vướng mắc)
BID	Nhà thầu và phân tích AI	L3	ProcurementPackage, ContractorProposal, AnalysisRun, Finding, ContractorEvaluation	PRJ, MDM, LLM, DOC	—
LND	GPMB, bồi thường, TĐC	L3	LandParcel, AffectedHousehold, CompensationPlan, CompensationPayment, LandComplaint	PRJ, CAP, DOC	—
CTR	Hợp đồng và thực hiện	L3	Contract, BoqLine, Amendment, ChangeEvent, PotentialChangeOrder, ChangeOrder, VolumeAcceptance, RetentionHold	PRJ, MDM, CAP, BID, DOC	QMS (nghiệm thu chất lượng đạt)
QMS	Chất lượng, nhật ký thi công, nghiệm thu	L4	ConstructionDiary, Inspection, QualityAcceptance, SitePhoto	CTR, PRJ, DOC	—
PAY	Thanh toán và Kho bạc	L4	PaymentRequest, AdvanceLedger, CumulativeLedgerEntry, TreasuryImport, TreasuryTransaction, Reconciliation	CTR, CAP, DOC	—
DIS	Báo cáo giải ngân	L5	ReportingPeriod, ReportRevision, FundingSnapshotLine, PeriodSnapshot	PRJ, CAP, PAY, DOC	—
MNE	Giám sát, đánh giá đầu tư	L5	MonitoringReport, InvestmentEvaluation, PublicDisclosure	PRJ, CAP, DIS, PAY, CTR, DOC	—
AUD	Thanh tra, kiểm toán	L5	AuditEngagement, AuditConclusion, Recommendation, RemediationAction	PRJ, CTR, PAY, ISS, DOC	—
AST	Bàn giao tài sản và bảo hành	L5	AssetHandover, WarrantyObligation	PRJ, CTR, QMS, PAY, DOC	—
BI	BI và dashboard động	L6	MetricDefinition, DatasetVersion, DashboardVersion, QueryContext, ExportJob	DGV	sự kiện mọi module (projection)
HOME	Điều hành	L6	Watchlist, DirectiveAssignment, AlertAcknowledgement	BI, DIS, ISS	—
NOT	Notification Center	L6	NotificationEvent, WorkflowRun, RecipientPreference, Digest, DeliveryAttempt	IAM, ADM	sự kiện mọi module
OMNI	Tương tác đa kênh	L6	Conversation, ChannelMessage, InternalNote, ChannelAccount	NOT, IAM, LLM	—
MOB	Ứng dụng iOS và Android	L6	DeviceRegistration, SyncScope (bảng `sync_membership_scope`), MobileCommandReceipt	IAM, ADM	ADM (grant đổi)

Ranh giới nghiệm thu: CTR sở hữu khối lượng nghiệm thu dùng cho thanh toán (`VolumeAcceptance`); QMS sở hữu kiểm tra và biên bản nghiệm thu chất lượng. CTR chỉ cho `VolumeAcceptance` sang APPROVED khi đã nhận sự kiện `qms.quality_acceptance.approved.v1` (nếu hợp đồng yêu cầu). PAY khóa hàng hợp đồng và ghi sổ lũy kế (R7). DOC tham chiếu đối tượng nghiệp vụ bằng `subject_ref (module, id)` nên không phụ thuộc module nghiệp vụ.

Đồ thị phụ thuộc

Mũi tên `A → B`: A gọi interface công khai của B (phụ thuộc compile-time). `A ⇠ B`: A nhận sự kiện của B qua outbox (không phụ thuộc compile-time). Mọi module phụ thuộc kernel.

```
L6  HOME → BI, DIS, ISS            BI → DGV        BI ⇠ (mọi module, projection)
    NOT  → IAM, ADM                NOT ⇠ (mọi module)
    OMNI → NOT, LLM, IAM           MOB → IAM, ADM  (app Flutter gọi API công khai DIS/ISS/QMS/PRJ/NOT)
          │
L5  DIS → PAY, CAP, PRJ, DOC       MNE → DIS, PAY, CTR, CAP, PRJ, DOC
    AUD → PAY, CTR, ISS, PRJ, DOC  AST → PAY, QMS, CTR, PRJ, DOC
```



Quy tắc ép buộc: (1) phụ thuộc chỉ đi xuống lớp thấp hơn hoặc ngang lớp theo đúng cạnh trong đồ thị; (2) không chu trình; (3) chỉ import `modules/<code>/application/public/**`; (4) thông tin đi ngược lên chỉ bằng sự kiện có version. CI chạy dependency-cruiser với rule sinh từ bảng trên; vi phạm chặn merge (architecture test suite, D-B07). Thêm cạnh mới cần CR và cập nhật bảng.

Ranh giới dữ liệu và cách ly tenant

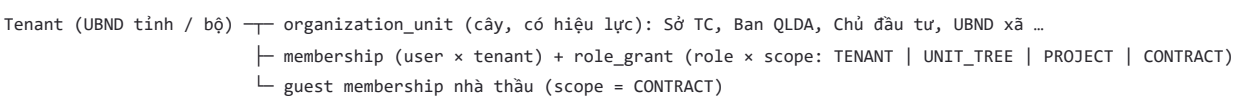
Mặc định pool database với tenant_id trên mọi bảng nghiệp vụ và RLS defense-in-depth, composite foreign keys gồm tenant_id. Tài khoản ứng dụng không có BYPASSRLS và không là table owner khi chạy runtime. Context tenant thiết lập bằng SET LOCAL trong transaction, không giữ trên connection dùng chung sau request. Background job có signed tenant context; không chấp nhận tenant_id tùy ý từ queue chưa xác thực.

Object key bắt đầu tenant UUID; quyền download kiểm ở server rồi tạo URL ngắn hạn. Search index và vector store lọc tenant + ACL trước retrieval; kiểm quyền lại khi mở file. Cache key gồm tenant, scope hash, dataset version, query, filters và snapshot. Log/traces có tenant tag nhưng redact nội dung. Analytics export/public sharing là một đường dữ liệu cần kiểm thử riêng.

Gói Enterprise/Private có thể dùng database và encryption key riêng theo deployment stamp. Tenant registry ghi placement. Chuyển pooled sang dedicated phải freeze write có thời hạn, copy, verify checksum/count/totals, cutover routing, quan sát và rollback theo runbook. Không sao chép toàn bộ DB chứa tenant khác để phục hồi một tenant.

Mô hình tenant (R6) (Cập nhật 1.4 — CR-04-07)

- Tenant là cơ quan chủ quản ký hợp đồng: một UBND tỉnh hoặc một bộ/ngành. Một tenant có một hợp đồng thuê bao, một cấu hình thương hiệu, một không gian dữ liệu cách ly.
- Sở, ban QLDA, chủ đầu tư, UBND xã/phường là `organization_unit` trong tenant, dạng cây có hiệu lực theo thời gian (`valid_from`, `valid_until`, `successor_id`). Không hard-code cấp huyện; hỗ trợ sáp nhập và đơn vị kế thừa.
- Người dùng có `membership` (user × tenant × đơn vị chính) và `role_grant` (role × scope). Scope gồm: cả tenant, cây đơn vị (đơn vị và con cháu), danh sách dự án, hợp đồng. Quyền đọc dữ liệu = tenant boundary (RLS) ∩ scope grant ∩ classification.
- Tổng hợp toàn tỉnh, xếp hạng giải ngân, điều chuyển vốn giữa dự án chạy trong một tenant với grant scope "cả tenant".
- Nhà thầu dùng guest membership (`membership.kind = GUEST`) với scope là các hợp đồng của mình; không thấy danh mục dự án, vốn hoặc nhà thầu khác.
- Báo cáo lên cơ quan cấp trên đi qua văn bản DOC hoặc xuất tệp; không đọc chéo tenant.
- Chuyển dự án giữa đơn vị trong tenant là command có audit (`TransferProjectOwnership`); chuyển giữa tenant là export/import có audit và xác nhận của hai System Admin; không có truy vấn cross-tenant ở runtime.
- Một người có thể thuộc nhiều tenant; phiên làm việc luôn có đúng một tenant đang hoạt động, đổi tenant cấp lại token và xóa dữ liệu cục bộ của tenant cũ trên mobile.
- Placement: mặc định pool (chung cụm Postgres, cách ly bằng RLS). Hợp đồng yêu cầu cách ly cao dùng silo (database riêng, khóa mã hóa riêng) bằng cùng mã provisioning; tenant registry ghi placement. Chuyển pool → silo: freeze ghi có thời hạn, copy, kiểm checksum/số dòng/tổng tiền, chuyển routing, quan sát, rollback theo runbook. Không sao chép toàn bộ DB chứa tenant khác để phục hồi một tenant.



PostgreSQL và RLS (Cập nhật 1.4 — CR-04-08)

1. Mọi bảng dữ liệu tenant có `tenant_id uuid NOT NULL`, khóa chính `(tenant_id, id)`, khóa ngoại composite `(tenant_id, x_id)` để không thể tham chiếu chéo tenant. Bảng control plane nằm ở schema `control`, không mang RLS tenant nhưng chỉ role control

plane có quyền.

2. Mọi bảng tenant: `ENABLE ROW LEVEL SECURITY` và `FORCE ROW LEVEL SECURITY`.
3. Chính sách: một policy PERMISSIVE `tenant_access` và một policy RESTRICTIVE `tenant_boundary`, cả hai cho mọi lệnh với `USING` và `WITH CHECK` là `tenant_id = nullif(current_setting('app.tenant_id', true), '')::uuid`. Lý do cần cả hai: PostgreSQL từ chối mọi dòng nếu chỉ có policy RESTRICTIVE; RESTRICTIVE bảo đảm policy cho phép thêm sau này (ví dụ scope đơn vị) không nới ranh giới tenant. Bảng nhạy cảm (hộ dân LND, đề xuất nhà thầu BID, dữ liệu cá nhân) thêm policy RESTRICTIVE theo `app.scope_units` khi đặc tả phân hệ yêu cầu.
4. Role: `machvon_owner` sở hữu bảng, chỉ dùng cho migration; `machvon_app` (runtime API/worker) `NOSUPERUSER NOBYPASSRLS`, không sở hữu bảng; `machvon_control` cho control plane; `machvon_reporting` cho read replica, cũng `NOBYPASSRLS`; `machvon_sync` cho PowerSync có `REPLICATION` và chỉ `SELECT` trên publication `powersync` gồm bảng/cột trong hợp đồng sync.
5. Kernel mở transaction, chạy `SET LOCAL app.tenant_id`, `SET LOCAL app.actor_id`, `SET LOCAL app.request_id` trước câu lệnh đầu; connection pool chế độ transaction an toàn vì `SET LOCAL` hết hiệu lực khi commit/rollback. Thiếu context → `nullif` trả NULL → đọc 0 dòng, ghi lỗi `WITH CHECK`.
6. View dùng `security_invoker = true`. Hàm `SECURITY DEFINER` bị cấm trừ danh sách allowlist có review, cố định `search_path`.
7. Bảng `audit_entry` chỉ cấp `INSERT, SELECT` cho `machvon_app`; không `UPDATE/DELETE`; mỗi dòng có `prev_hash` và `hash` (chuỗi băm theo tenant) để phát hiện sửa ngoài ứng dụng.
8. Index: mỗi cột `*_id` có index dẫn đầu `tenant_id` (`CREATE INDEX <table>_<col>_idx ON <table> (tenant_id, <col>)`), cộng index cho truy vấn danh sách/báo cáo chính (P1).
9. Kiểm trong CI: truy vấn catalog xác nhận mọi bảng có cột `tenant_id` đều có `relrowsecurity` và `relforcerowsecurity` = true và đủ hai policy; test kết nối bằng `machvon_app` không đặt context phải đọc 0 dòng.
10. Tiền là `numeric(24,0)` VND nguyên; bất biến tiền (tổng đề nghị ≤ giá trị nghiệm thu/hợp đồng, một nghiệm thu một đề nghị còn hiệu lực) bằng ràng buộc DB + khóa hàng hợp đồng trong transaction (R7); sửa sai bằng bút toán đảo.

Danh tính, phiên và vai trò quản trị (Cập nhật 1.4 — CR-04-09)

- Keycloak cấp token OIDC; API xác thực chữ ký, audience, hạn; tenant đang hoạt động lấy từ membership đã xác thực, header `X-Tenant-ID` chỉ là đề nghị chọn.
- MFA bắt buộc cho System Admin, Platform Operator, Tenant Admin, Billing Admin, AI Admin, Auditor và mọi người có quyền phê duyệt tiền; WebAuthn bắt buộc cho control plane.
- Control plane dùng client/audience riêng; System Admin chọn tenant đích qua tham số đã xác thực, mọi lệnh ghi được kiểm lại quyền trong transaction và ghi audit có tenant đích. Không cấp BYPASSRLS cho runtime. Truy cập nội dung tenant của Platform Operator chỉ qua break-glass (SAS-19): ticket, đồng ý của tenant, thời hạn, audit.
- Chống tự nâng quyền: người dùng không cấp được role/permission vượt quyền mình đang có; role tùy biến của tenant không chứa permission `system.*`; maker ≠ checker cho phê duyệt (DoA matrix ADM).

Đồng bộ mobile bằng PowerSync (A1) (Cập nhật 1.4 — CR-04-10)

PowerSync đọc WAL bằng role replication nên không đi qua RLS. Cách ly tenant trên mobile là trách nhiệm của sync rules:

- JWT cho PowerSync do backend MACHVON cấp (TTL ≤ 5 phút), chứa `sub`, `tenant_id` của tenant đang hoạt động và `scope_version`. Không dùng client parameter cho phân quyền.
- Mọi bucket có tham số lấy từ bảng `sync_membership_scope` (MOB sở hữu, ADM cập nhật qua sự kiện) lọc theo `request.user_id()` và tenant trong JWT; data query luôn có `WHERE tenant_id = bucket.tenant_id` và điều kiện scope (đơn vị/dự án/hợp đồng). Ví dụ minh họa (cú pháp được xác nhận ở spike R1):

```
bucket_definitions:
  dis_reports_by_unit:
    parameters: >
      SELECT s.tenant_id, s.org_unit_id FROM sync_membership_scope s
      WHERE s.user_id = request.user_id()
        AND s.tenant_id = request.jwt() ->> 'tenant_id'
        AND s.revoked = false
    data:
      - SELECT id, tenant_id, project_id, period_id, status, version, submitted_at
        FROM report_revision
        WHERE tenant_id = bucket.tenant_id AND org_unit_id = bucket.org_unit_id
```

- Hợp đồng sync liệt kê bảng và cột được sync cho từng màn hình MOB; trường tiền được sync ở dạng chỉ đọc; dữ liệu cá nhân (hộ dân LND, CCCD) không sync trừ khi đặc tả phân hệ cho phép theo vai trò.
- Thu hồi membership/grant → dòng `sync_membership_scope` bị đánh dấu `revoked` → bucket rỗng ở lần sync kế tiếp và app xóa dòng cục bộ.
- Logout hoặc đổi tenant: app xóa SQLite cục bộ, khóa mã hóa và cache file của tenant cũ. Nếu hàng đợi command còn mục chưa gửi, app chặn đổi tenant cho tới khi người dùng gửi xong hoặc chủ động hủy; command không bao giờ được gửi dưới tenant khác (gắn `tenant_id`, `user_id` trong envelope).
- Ghi từ mobile: hàng đợi upload của PowerSync gọi API command của backend (`POST /sync/batches` hoặc command của phân hệ) với Idempotency-Key = `local_uuid` và `base_server_version`; không ghi trực tiếp bảng. Không last-write-wins cho tiền.

Thành phần và lựa chọn công nghệ đề xuất

(Cập nhật 1.4 — CR-04-11) Web: TypeScript/React (Vite) có hệ thống design token và accessible components (D-B07). Mobile: Flutter (D-B12, thay React Native của D-B07); các spike về chữ ký số, camera, biometric, secure storage và offline vẫn bắt buộc trước slice tương ứng, nhưng không còn dùng để chọn framework. Core API: TypeScript/NestJS (D-B07) thay phương án .NET hoặc Java; dùng một nền tảng chính, không trộn ngôn ngữ không cần thiết. Mockup hiện tại không áp đặt framework; giao diện phải tuân thủ mockup về token, component và layout (D-B11).

(Cập nhật 1.4 — CR-04-12) PostgreSQL cho transaction/decimal/versioning; object storage S3-compatible cho hồ sơ; Redis cho cache/rate limit/reservation hỗ trợ nhưng ngân sách sổ cái vẫn bền vững ở Postgres; outbox relay + inbox có retry/DLQ thay broker ở R0–R1 (broker riêng chỉ khi đo được lag vượt ngưỡng, ghi CR); data warehouse hoặc column store khi tải BI vượt khả năng read replica/materialized views. Search và vector là projection có thể dựng lại, không là nguồn số tài chính. IdP (Keycloak) hỗ trợ OIDC/SAML; chữ ký số và thanh toán qua adapter hợp đồng riêng.

(Cập nhật 1.4 — CR-04-13) Các lựa chọn thành phần đã được chốt bởi D-B03, D-B07, D-B12 (bảng Stack bên dưới), không còn là ADR đề xuất. Phiên bản và library cụ thể vẫn chưa cam kết khi chưa kiểm tra môi trường triển khai. Tách interface để thay cloud/private hạ tầng, LLM, kênh gửi và BI renderer.

Stack (Cập nhật 1.4 — CR-04-14)

Lớp	Lựa chọn	Ghi chú ràng buộc
Backend	TypeScript, NestJS modular monolith	Một repo; lint ranh giới module; OpenAPI là hợp đồng nguồn (`03_Engineering/openapi.json`)
Web	React + TypeScript (Vite)	Tokens từ `design_tokens.json`; component families tài liệu 06; i18n key `module.screen.action.state`
Mobile	Flutter (D-B12) cho iOS/Android	Client Dart sinh từ `openapi.json`; `ThemeData` sinh từ `design_tokens.json`; PowerSync Flutter SDK; OIDC Authorization Code + PKCE qua system browser; secure storage
Database	PostgreSQL 16+ tự quản trên VM cloud nội địa	`wal_level=logical` cho PowerSync; schema `machvon` (data plane) và `control` (control plane); read replica cho BI; pgvector cho truy xuất AI có lọc tenant
Cache, rate limit	Redis	Key bắt buộc tiền tố `t:{tenant_id}:`; không là nguồn sự thật (idempotency, ngân sách, sổ cái ở Postgres)
Identity	Keycloak tự host	OIDC; MFA TOTP/WebAuthn; realm `machvon` cho tenant users, client riêng cho control plane; vai trò ánh xạ sang role_grant trong ADM (Keycloak không giữ scope nghiệp vụ)
Điều phối	Temporal tự host (persistence Postgres riêng)	Chủ duy nhất cho luồng dài (R9)
Sự kiện	Transactional outbox + relay polling + inbox	Không thêm broker riêng ở R0–R1; đánh giá broker khi đo được lag vượt ngưỡng (CR)
AI	LiteLLM proxy + Langfuse tự host	Virtual key theo tenant, budget, fallback; trace có mask PII; định tuyến theo phân loại (R5)
Offline mobile	PowerSync Open Edition tự host	Sync rules theo tenant/scope (A1); chỉ xếp hàng command
Object storage	S3-compatible của cloud nội địa	Key `tenants/{tenant_id}/{module}/{uuid}`; versioning; quét virus trước khi liên kết
Secrets	KMS của cloud nội địa nếu đạt tiêu chí, nếu không OpenBao tự host [GIẢ ĐỊNH]	Không secret trong repo, image hoặc log
Quan sát	OpenTelemetry SDK + Collector; lưu metric/log/trace tự host [GIẢ ĐỊNH: Prometheus, Loki, Tempo, Grafana]	Thuộc tính `tenant_id`, không PII

Lớp	Lựa chọn	Ghi chú ràng buộc
Review	Codex review mỗi slice (D-B05)	Claude không tự chấm review cuối

Thứ tự và thời điểm dựng thành phần theo R1 (mục Hạ tầng theo slice). Không dùng Realm Device Sync (ngừng 30/09/2025).

Điều phối luồng dài bằng Temporal (R9) (Cập nhật 1.4 — CR-04-15)

- Temporal là chủ duy nhất cho: provisioning tenant (SAS-02), phê duyệt nhiều bước theo `workflow_version` của tenant (một workflow tổng quát diễn giải định nghĩa), ký số/cấp số DOC, import tệp Kho bạc/hệ thống ngoài, nhắc hạn/leo thang/timer, hủy, retry, nâng version.
- Chuyển trạng thái ngắn trong một transaction vẫn nằm trong domain. Workflow không bao giờ ghi trạng thái trực tiếp: mọi bước gọi command domain qua command bus nội bộ với Idempotency-Key `wf:{workflowId}:{activityId}:{attempt-group}`; bảng transition (from, command, to, quyền, guard) của domain là guard bắt buộc; guard từ chối → workflow nhận Problem code và rẽ nhánh bù trừ/thông báo.
- Mỗi workflow có `tenant_id` trong memo và search attribute; activity khởi tạo transaction với `SET LOCAL app.tenant_id` từ context đã ký, không từ input tùy ý. Search attribute không chứa PII.
- `workflow_version` được ghim khi bắt đầu; đổi định nghĩa phê duyệt chỉ áp dụng cho luồng mới. Thay đổi mã workflow dùng patching/worker versioning, có test replay lịch sử.
- Namespace theo môi trường; task queue theo module. Temporal dựng ở slice đầu tiên cần nó (provisioning tenant R0) kèm runbook + restore test (R1).

Command, outbox, inbox, idempotency (Cập nhật 1.4 — CR-04-16)

- Mọi thay đổi trạng thái là domain command `POST /api/v1/<resource>/{id}/<action>` có `x-permission`, header `Idempotency-Key` bắt buộc, `If-Match` bắt buộc khi sửa bản ghi có version; lỗi trả RFC 7807 Problem với `code` ổn định (400 INVALID_REQUEST, 401 SESSION_EXPIRED, 403 SCOPE_DENIED/ENTITLEMENT_DENIED, 404 RESOURCE_NOT_FOUND, 409 VERSION_CONFLICT/IDEMPOTENCY_CONFLICT/PERIOD_LOCKED, 422 VALIDATION_FAILED, 429 RATE_LIMIT/BUDGET_EXCEEDED, 503 PROVIDER_UNAVAILABLE).
- Không endpoint chung nào được đổi `status`, `tenant_id`, role/grant hoặc số tiền đã chốt; DTO request là allowlist, trường thừa bị từ chối 400.
- `idempotency_record` (tenant_id, actor_id, operation_id, key) lưu trong Postgres cùng transaction với thay đổi: `request_hash`, trạng thái, mã HTTP và body phản hồi; giữ tối thiểu 72 giờ [GIẢ ĐỊNH]. Cùng key + cùng hash → trả lại đúng phản hồi; cùng key + hash khác → 409 IDEMPOTENCY_CONFLICT; key đang xử lý → 409 kèm `Retry-After`.
- Trùng ý định nghiệp vụ khác key (hai người, hai màn hình) được chặn bằng ràng buộc nghiệp vụ trong DB (unique một phần, sổ lũy kế), không dựa vào idempotency key (R7).
- Transaction ghi: thay đổi aggregate + `audit_entry` + `outbox_event` (id, tenant_id, aggregate_type, aggregate_id, event_type, schema_version, payload tối thiểu, occurred_at) trong cùng commit. Relay đọc `FOR UPDATE SKIP LOCKED`, giao at-least-once, giữ thứ tự theo aggregate; consumer ghi `inbox_record (consumer, event_id)` trong transaction xử lý để bỏ qua bản lặp. Lỗi lặp lại quá ngưỡng → dead-letter có cảnh báo và owner. Không tuyên bố exactly-once end-to-end.
- Tên sự kiện `<module>.<aggregate>.<past_tense>.v<n>`; thay đổi không tương thích tạo version mới, consumer đọc song song hai version trong thời gian chuyển.

Tích hợp dựa trên tệp và trạng thái adapter (Cập nhật 1.4 — CR-04-17)

Hệ thống TTQG về đầu tư công, muasamcong, dịch vụ công Kho bạc/TABMIS không có API công khai cho bên thứ ba; không thiết kế lời gọi API giả định. Tích hợp qua tệp mẫu (import/export) và đối soát. Mỗi adapter có port, mock có contract cho test tự động, và trạng thái:

- VERIFIED: hợp đồng đã kiểm với sandbox/đặc tả chính thức của bên cung cấp, có bằng chứng.
- PROPOSED: hợp đồng soạn từ tài liệu công khai hoặc mẫu tệp, chưa kiểm với bên cung cấp.
- MOCK: chỉ có mock phục vụ test; chưa có đặc tả bên ngoài.
- MISSING: chưa có đặc tả, hợp đồng hay bên cung cấp; tính năng dùng thao tác thủ công/tệp.

Adapter	Hình thức	Trạng thái 22/10/2026	Điều kiện nâng trạng thái
Kho bạc (sao kê, kết quả thanh toán)	Import tệp sao kê + đối soát; xuất hồ sơ theo mẫu NĐ 254/2025	PROPOSED (tệp); API: MISSING	Mẫu tệp thật đã ẩn danh + xác nhận CXN-08 (D05)

Adapter	Hình thức	Trạng thái 22/10/2026	Điều kiện nâng trạng thái
Hệ thống TTQG về đầu tư công	Xuất/nhập tệp mẫu (mã dự án, kế hoạch)	PROPOSED (tệp); API: MISSING	Mẫu tệp từ cơ quan khách hàng (D05)
muasamcong	Nhập tệp kết quả lựa chọn nhà thầu	PROPOSED (tệp); API: MISSING	Mẫu tệp thật (D05)
LGSP/NDXP liên thông văn bản	Qua LGSP của cơ quan khách hàng	PROPOSED [CXN-06]	Đặc tả LGSP của tenant pilot
Ký số (PAdES, CA)	Adapter ký trong hệ thống + đường tải lên văn bản đã ký	PROPOSED; spike CA sandbox ở R0	Spike R0 đạt (R8, D05)
Zalo OA/ZNS	Adapter gửi + webhook	PROPOSED	Tài khoản OA/template được duyệt (D06)
WhatsApp Business Platform	Adapter gửi + webhook, opt-in, cửa sổ 24h	PROPOSED	Tài khoản doanh nghiệp + template (D06)
Email (SMTP/Graph)	Adapter gửi	PROPOSED	Sender/domain được xác minh (D06)
Push APNs/FCM	Adapter gửi	PROPOSED	Tài khoản developer của bên vận hành
Model AI trong nước/tự host	Qua LiteLLM	PROPOSED	Eval đạt ngưỡng (D07)
Model AI quốc tế	Qua LiteLLM, chỉ dữ liệu PUBLIC	PROPOSED, bị khóa	D07 duyệt + đánh giá chuyển dữ liệu
Hóa đơn điện tử (NĐ 123/2020 sửa bởi NĐ 70/2025)	Adapter nhà cung cấp Việt Nam	MISSING	Chọn nhà cung cấp (D08)
SSO/VNeID	OIDC/SAML	MISSING	Hợp đồng và đặc tả

Import tệp idempotent (A3): tính SHA-256 của tệp + khóa nghiệp vụ từng dòng (ví dụ số chứng từ Kho bạc + ngày + tài khoản); nạp lại cùng tệp trả "đã nạp" và không tạo bản ghi; dòng lỗi vào quarantine có báo cáo; chênh lệch đối soát tạo hạng mục có owner và hạn xử lý.

Mô hình miền và nguồn sự thật

Tenant → OrganizationUnit hiệu lực theo thời gian → Membership/RoleGrant/Delegation. Project → Component/WBS → PlanVersion → AllocationLine. Project → ReportingPeriod → ReportRevision → FundingSnapshotLine. ReportRevision được accepted là nguồn báo cáo nội bộ; TreasuryTransaction confirmed là nguồn đối soát thực trả; không trộn hai nguồn bằng phép cộng.

(Cập nhật 1.4 — CR-04-18) Project → ProcurementPackage → ContractorProposal → DocumentVersion → AnalysisRun → Finding/Evidence → ExpertReview. Contract/Amendment/VolumeAcceptance/PaymentRequest/AdvanceLedger/CumulativeLedgerEntry liên kết cùng tenant/project (VolumeAcceptance thay tên "Acceptance" của baseline 1.3; CumulativeLedgerEntry là sổ lũy kế R7). Issue → Assignment/Comment/Attachment/Resolution. MetricDefinition → DatasetVersion → DashboardVersion → QueryContext → ExportJob. NotificationEvent → WorkflowRun → RecipientDecision → DeliveryAttempt. Conversation → ChannelMessage/InternalNote. Tenant → Subscription → UsageMeter/Invoice; Tenant → LicenseRevision → EntitlementSnapshot. OutgoingDocument → DocumentNumberRegister/Dossier; Project → LandParcel/CompensationPlan, PermitDossier, ConstructionDiary/QualityAcceptance, AuditEngagement, AssetHandover, MonitoringReport.

Lịch sử tổ chức dùng valid_from/valid_to; báo cáo có thể xem theo tổ chức tại thời điểm chốt hoặc cơ cấu hiện tại, phải có nhãn. Không hard-code cấp huyện hay mô hình hành chính vào schema; hỗ trợ cơ cấu đã thay đổi và đơn vị kế thừa.

(Cập nhật 1.4 — CR-04-19) Quy tắc pháp lý và mẫu biểu là dữ liệu trong rule registry/DOC có `legal_basis`, `effective_from`, `effective_until`; bản ghi nghiệp vụ lưu ID phiên bản đã áp dụng (R4).

Kiến trúc BI và drill down

(Cập nhật 1.4 — CR-04-20) Operational DB → outbox → projection có kiểm tra → facts/dimensions → semantic metrics → query service → dashboard/export. Nguồn sự kiện là transactional outbox (K4); CDC không được chọn ở baseline 1.4. Fact allocation có grain dòng phân bổ theo phiên bản; fact disbursement snapshot theo dự án/kỳ/nguồn; fact treasury transaction theo giao dịch; fact LLM attempt theo request attempt; fact notification theo delivery attempt; fact subscription usage theo meter event.

(Cập nhật 1.4 — CR-04-21) Dimensions: tenant, thời gian, tổ chức SCD2, dự án, nguồn vốn, chương trình, channel/model/package. BI query service chỉ nhận metric/dimension IDs, filters, `as_of_period` và snapshot token; compiler tạo truy vấn allowlisted parameterized. Không cho browser gửi SQL vào warehouse hay bất kỳ kho nào. Kỳ có trạng thái Open/SoftClosed/Locked, mở lại có lý do; PeriodSnapshot đóng băng số liệu kỳ; dashboard toàn tỉnh đọc snapshot/materialized view trên read replica, không tính lại từ OLTP mỗi lần mở (P2). Aggregate table và cache giữ scope/version; lineage từ metric xuống source record và evidence.

Kiểm soát cardinality, timeout, row limit, concurrency và chi phí theo tenant. Truy vấn nặng trả job_id và notification khi xong. Đối với số liệu đã chốt, drill luôn dùng snapshot đó; refresh là thao tác rõ ràng, không tự nhảy về số mới làm tổng khác con.

(Cập nhật 1.4 — CR-04-22) Export/dashboard đã lưu kiểm lại quyền hiện tại khi chạy.

Kiến trúc AI và tương tác

AI gateway là điểm duy nhất được gọi provider; registry xác định model capability, region, pricing và trạng thái. Policy kiểm tra classification/retention, quota và task profile. Worker lưu provenance và chạy deterministic calculation ngoài LLM. Mỗi retry/fallback thành attempt có chi phí và bằng chứng model thực tế. Prompt/hồ sơ không được trực tiếp nắm API key hoặc quyền gửi thông báo.

Notification orchestration tách business transaction. Domain phát event, resolver tìm người nhận, policy kiểm consent/preferences, template render, scheduler, queue, adapter gửi. Hội thoại và notification có liên kết nhưng khác lifecycle: một notification gửi đi không tự thành hội thoại có quyền truy cập hồ sơ. Channel accounts thuộc tenant, hoặc shared provider account có virtual partition và mapping đã kiểm soát.

AI: định tuyến theo phân loại dữ liệu (R5) và tương tác (Cập nhật 1.4 — CR-04-23)

- Mỗi request AI mang `data_classification` ∈ {PUBLIC, INTERNAL, CONFIDENTIAL, PERSONAL, IMPORTANT_CORE} xác định từ nguồn dữ liệu (lấy mức cao nhất của tài liệu/trường được đưa vào prompt), không do client khai.
- PUBLIC hoặc đã ẩn danh: được tới model quốc tế chỉ khi D07 duyệt và tenant bật. INTERNAL trở lên: chỉ tới model trong nước hoặc tự host trên cloud nội địa. LiteLLM chọn route theo bảng chính sách; không có route hợp lệ → từ chối với Problem `AI_ROUTE_NOT_ALLOWED`, không hạ cấp phân loại.
- AI gateway (module LLM) là điểm duy nhất gọi provider; registry ghi capability, vùng, giá, trạng thái. Policy kiểm classification, retention, quota, profile; đặt chỗ ngân sách trước khi gọi; mỗi retry/fallback là một attempt có chi phí và model thực tế; audit ghi route đã dùng.
- Chống prompt injection (OWASP LLM01): nội dung truy xuất và tài liệu tải lên là dữ liệu không tin cậy, được bọc tách khỏi chỉ dẫn hệ thống; tool AI theo allowlist chỉ đọc; mọi hành động ghi/tiền/quyết định cần bản ghi người duyệt; câu trả lời không có citation tới nguồn trong scope bị từ chối. Truy xuất vector lọc tenant + ACL trước khi tính tương đồng.
- Bộ eval chạy trên cả tuyến trong nước và tuyến quốc tế (khi có) trước khi bật profile; kết quả eval ký bởi chuyên gia (D07).
- Notification orchestration tách giao dịch nghiệp vụ: domain phát sự kiện, resolver tìm người nhận, policy kiểm consent/preference, template render, scheduler (timer trên Temporal), adapter gửi. Một thông báo đã gửi không tự thành hội thoại có quyền truy cập hồ sơ. Không đưa dữ liệu nhạy cảm vào push màn hình khóa hoặc email công khai.

Triển khai vận hành và mở rộng

Môi trường dev/test/staging/production tách credentials và dữ liệu. CI/CD kiểm schema migration, API compatibility, dependency scan, unit/integration/security tests. Rollout canary theo tenant cohort; feature flag rollback không thay schema ngược phá dữ liệu. Migration theo expand-contract, không xóa cột đang dùng bởi mobile cũ.

Sao lưu DB có PITR, object versioning, restore drill định kỳ và xác minh tổng tài chính sau restore. Metrics: p95 latency, error rate, queue age, stuck jobs, reconciliation backlog, budget reservation age, tenant isolation violations, notification failure, license propagation lag. Alert có owner/runbook; không tạo vòng lặp notification khi chính Notification Center hỏng, cần kênh vận hành độc lập.

Quotas theo tenant cho API concurrency, import size, query, AI, message, storage ngăn noisy neighbor. Tự mở rộng worker theo queue lag nhưng phải giữ provider quota và cost cap. Dùng bulkheads/circuit breaker để một kênh lỗi không kéo sập báo cáo lõi. Có trạng thái degraded và thời điểm dữ liệu gần nhất trên UI.

Hosting nội địa và tuân thủ (Cập nhật 1.4 — CR-04-24)

Yêu cầu	Căn cứ	Thiết kế
Dữ liệu, bản sao lưu, log và inference cho dữ liệu phân loại INTERNAL trở lên nằm tại Việt Nam	D-B03; Luật Dữ liệu 60/2024 + NĐ 165/2025 [CXN-13]; Luật An ninh mạng 116/2025 (hiệu lực 01/7/2026)	Cloud nội địa có hai vùng/hai trung tâm dữ liệu tại Việt Nam; object storage và backup cùng lãnh thổ; không dùng SaaS quan sát/AI nước ngoài cho dữ liệu nội dung
Dữ liệu cá nhân: consent, quyền chủ thể, DPO, đánh giá tác động	Luật BVDLCN 91/2025 + NĐ 356/2025 (hiệu lực 01/01/2026)	ConsentRecord (IAM) theo mục đích/kênh; quy trình yêu cầu của chủ thể; phân loại PERSONAL cho hộ dân LND, liên hệ OMNI; mask trong log/export
Chuyển dữ liệu ra nước ngoài	Luật BVDLCN 91/2025; NĐ 165/2025 [CXN-13]	Mặc định không chuyển; tuyến AI quốc tế chỉ nhận PUBLIC/ẩn danh sau đánh giá được duyệt (R5)
Hồ sơ cấp độ an toàn hệ thống thông tin	Văn bản thay NĐ 85/2016 [CXN-04]	Hồ sơ đề xuất cấp độ (dự kiến cấp 3) lập ở R4, trước go-live; cloud được chọn phải có hồ sơ/chứng nhận tương ứng
Ứng cứu sự cố và nhật ký an ninh	Luật An ninh mạng 116/2025 [CXN chi tiết nghĩa vụ]	Runbook sự cố có bước báo cáo theo nghĩa vụ được pháp chế xác nhận; log an ninh lưu trong nước, bất biến
Lưu trữ văn bản	Luật Lưu trữ 33/2024 + NĐ 113/2025; thời hạn [CXN-05]	RetentionPolicy là dữ liệu; legal hold chặn xóa

Tiêu chí chọn cloud nội địa: VM có thể cấu hình Postgres `wal_level=logical`; S3-compatible có versioning và replication giữa hai site; mạng riêng, WAF/chống DDoS; KMS có envelope encryption (nếu không, OpenBao tự host); hồ sơ cấp độ ATTT; SLA hạ tầng công bố; hỗ trợ GPU hoặc dịch vụ model trong nước cho tuyến AI (R5).

Môi trường (Cập nhật 1.4 — CR-04-25)

Môi trường	Mục đích	Dữ liệu	Tích hợp
local	Agent/dev chạy bằng docker compose	Synthetic fixtures	Mock
ci (ephemeral)	Test tự động mỗi PR, DB dựng mới	Synthetic	Mock có contract
test	Tích hợp liên module, E2E web/mobile	Synthetic có ID fixture	Mock + sandbox khi có
staging	Giống production về cấu hình, diễn tập migration/DR, UAT	Synthetic hoặc đã ẩn danh được Data Owner duyệt	Sandbox provider
production	Tenant thật trên cloud nội địa (pilot là cohort đầu)	Thật	Provider thật theo trạng thái VERIFIED
dr	Site thứ hai trong Việt Nam, nhận WAL/backup, dựng khi diễn tập hoặc thảm họa	Bản sao production	Như production

Mỗi môi trường có credentials, khóa và Keycloak realm riêng; không dùng dữ liệu production ở môi trường thấp hơn.

CI/CD (Cập nhật 1.4 — CR-04-26)

Pipeline mỗi PR (chặn merge khi đỏ): lint + typecheck; unit test; architecture test (dependency-cruiser theo đồ thị module); migration test (áp từ rỗng và từ version trước, expand-contract, kiểm RLS catalog); OpenAPI lint + kiểm mọi lệnh ghi có Idempotency-Key/If-Match/x-permission/Problem; contract test backend ↔ client Dart sinh từ OpenAPI (D-B12); integration test với Postgres thật; test cách ly tenant; dependency audit (`npm audit`/OSV cho npm, `dart pub outdated`/OSV cho pub) chặn mức critical/high chưa có ngoại lệ; SBOM CycloneDX; quét secret; quét image container; kiểm tra script nhất quán tài liệu `work/tools` khi đổi JSON/SQL/OpenAPI; Codex review (D-B05); người duyệt cho hạng mục bắt buộc (tiền, quyền, migration, mẫu văn bản pháp lý, quyết định AI) theo R2.

Triển khai: staging tự động sau merge; production thủ công có phê duyệt, canary theo cohort tenant, feature flag; migration expand-contract (không xóa cột đang được app N-1 dùng); rollback ứng dụng không rollback schema phá dữ liệu; outbox không mất khi rollback. Mobile phát hành staged rollout, API tương thích N và N-1.

Quan sát (observability) (Cập nhật 1.4 — CR-04-27)

- OpenTelemetry trace/metric/log cho API, worker, Temporal activity, outbox relay, PowerSync và LiteLLM; propagation `traceparent` xuyên request → outbox → worker → provider.
- Thuộc tính bắt buộc: `tenant_id` (UUID), `module`, `operation_id`, `command`, `outcome`, `problem_code`, `correlation_id`. Cấm: tên người, email, số điện thoại, CCCD, nội dung văn bản/prompt, token, số tài khoản. Collector có processor xóa thuộc tính ngoài allowlist; test CI quét log mẫu tìm mẫu PII.
- Chỉ số: availability và p95 theo operation, error rate, queue age, outbox lag, DLQ size, stuck workflow, reconciliation backlog, budget reservation age, vi phạm cách ly tenant (phải bằng 0), notification failure, license propagation lag, sync lag mobile, chi phí AI theo tenant.
- Cảnh báo có owner và runbook; kênh cảnh báo vận hành độc lập với Notification Center của sản phẩm.

Sao lưu, khôi phục và DR (Cập nhật 1.4 — CR-04-28)

- PostgreSQL: backup đầy đủ hằng ngày + lưu trữ WAL liên tục tới object storage ở site thứ hai (`archive_timeout` ≤ 60 giây) → RPO ≤ 15 phút; PITR giữ 35 ngày [GIẢ ĐỊNH, chốt ở D10]; standby đồng bộ trong vùng cho sự cố thường (mục tiêu chuyển đổi ≤ 15 phút).
- Object storage: versioning + replication sang site thứ hai; xóa mềm theo retention.
- Keycloak, Temporal, Langfuse lưu trên Postgres nên theo cùng chính sách; Redis và bucket storage PowerSync là dữ liệu dựng lại được, không phải nguồn sự thật; dữ liệu trace ClickHouse của Langfuse giữ theo retention, mất được chấp nhận [GIẢ ĐỊNH].
- Diễn tập khôi phục: hằng quý khôi phục toàn bộ vào môi trường cách ly, đo RPO/RTO thực tế, so checksum, số dòng, tham chiếu file và tổng tiền; khôi phục một tenant (SAS-21) bằng dựng bản sao cách ly rồi trích dữ liệu của đúng tenant đó, không chép dữ liệu tenant khác. Mỗi diễn tập có biên bản.

Hạ tầng theo slice (R1) (Cập nhật 1.4 — CR-04-29)

Thành phần	Slice đầu tiên dùng	Điều kiện vào (bắt buộc cả ba)
PostgreSQL (+ WAL archive)	R0 nền tảng: tenant/RLS/IAM/audit/outbox	Runbook; backup + PITR restore đã thử; cảnh báo replication lag, dung lượng, kết nối
Object storage	R0: tải logo SAS-04, tệp đính kèm	Runbook; khôi phục phiên bản đối tượng đã thử; cảnh báo lỗi ghi
Keycloak	R0: đăng nhập, MFA	Runbook; export realm + restore DB đã thử; cảnh báo lỗi đăng nhập
OpenTelemetry Collector + lưu trữ quan sát	R0 (cần cho cảnh báo của mọi thành phần)	Runbook; khôi phục cấu hình dashboard/alert; cảnh báo về chính collector
Temporal	R0: provisioning tenant (SAS-02)	Runbook; restore persistence + replay đã thử; cảnh báo workflow kẹt
Redis	Slice đầu cần rate limit/cache phân tán (dự kiến R0 throttling đăng nhập)	Runbook; kiểm khởi động lạnh không mất dữ liệu nguồn; cảnh báo bộ nhớ
PowerSync	R1: slice MOB offline đầu tiên (báo cáo tuần)	Runbook; dựng lại bucket storage từ Postgres đã thử; cảnh báo sync lag
LiteLLM + Langfuse (+ ClickHouse)	Slice LLM/BID đầu tiên	Runbook; restore Postgres của Langfuse/LiteLLM đã thử; cảnh báo chi phí và lỗi route

Một thành phần chưa đạt điều kiện vào thì slice phụ thuộc không được DONE. Lịch cụ thể gắn backlog ở `09_Ke_hoach_trien_khai.md`.

SLO, RPO và RTO (Cập nhật 1.4 — CR-04-30)

Baseline 1.3 đặt SLO 99,9%/tháng và RTO 4 giờ mà không nói quan hệ; một sự cố DR 4 giờ bằng khoảng 5,5 lần ngân sách lỗi tháng của SLO 99,9%. Quy tắc baseline 1.4:

1. SLO dịch vụ lõi (API command/query của DIS, CAP, PAY, PRJ, IAM) = 99,9% theo cửa sổ trượt 30 ngày, đo bằng tỷ lệ request hợp lệ không trả 5xx/timeout tại reverse proxy. Ngân sách lỗi = 43 phút 12 giây mỗi 30 ngày.
2. RTO ≤ 4 giờ và RPO ≤ 15 phút là trần phục hồi khi tuyên bố thảm họa (mất site, hỏng dữ liệu phải khôi phục) cho cấu hình tiêu chuẩn; đây không phải cam kết availability. Sự cố thường (mất node, lỗi triển khai) phải xử lý bằng HA/rollback với mục tiêu ≤ 15 phút để nằm trong ngân sách.
3. Thời gian gián đoạn do thảm họa được tính đầy đủ vào ngân sách lỗi, không loại trừ. Một sự cố DR dài hơn 43 phút làm vỡ SLO tháng đó; việc vỡ được báo cáo minh bạch.
4. Khi ngân sách lỗi cạn: dừng triển khai tính năng (chỉ cho bản sửa độ tin cậy/bảo mật) tới khi ngân sách 30 ngày hồi lại dương; postmortem trong 5 ngày làm việc; hành động khắc phục có owner.
5. SLA hợp đồng (D10) là mức thương mại riêng, không được cao hơn SLO nội bộ và phải ghi rõ cách tính thảm họa; gói yêu cầu RTO ngắn hơn cần placement silo + standby nóng ở site thứ hai, định giá riêng.

Các quyết định kiến trúc cần phê duyệt

ADR01: modular core + worker tách tải. ADR02: pooled RLS mặc định, dedicated tùy hợp đồng. ADR03: accepted report snapshot không thay transaction ledger. ADR04: BI semantic layer thống nhất mọi dashboard. ADR05: AI gateway và reservation trước gọi. ADR06: notification at-least-once với dedupe, không tuyên bố exactly-once end-to-end. ADR07: mobile offline chỉ cho nháp. ADR08: license kiểm server, private lease tùy chọn. ADR09: browser mockup không phải ứng dụng production. ADR10: quyền xem của platform support chỉ cấp tạm theo ticket.

(Cập nhật 1.4 — CR-04-31) Trạng thái ADR01–ADR10 ở baseline 1.4: tất cả đã được phê duyệt và cụ thể hóa. ADR01 → K1 (modular monolith + process worker). ADR02 → K2 + R6 (pool RLS mặc định, silo theo hợp đồng). ADR03 → mục Mô hình miền (ReportRevision accepted khác TreasuryTransaction confirmed) + R7 (sổ lũy kế). ADR04 → mục Kiến trúc BI (semantic layer, `as_of_period`, PeriodSnapshot). ADR05 → mục AI + R5 (đặt chỗ ngân sách trước khi gọi, định tuyến theo phân loại). ADR06 → K4 (outbox at-least-once, inbox dedupe). ADR07 → A1 + `05_modules/MOB.md`: offline chỉ lưu nháp và xếp hàng command, không ghi trực tiếp bảng, không last-write-wins tiền. ADR08 → `05_modules/SAS.md` (license kiểm server). ADR09 → D-B11 + R10 (mockup là chuẩn giao diện, không phải ứng dụng production). ADR10 → break-glass SAS-19.

Bảng quyết định baseline 1.4 (Cập nhật 1.4 — CR-04-32)

ID	Quyết định	Nguồn quyết định	Tác động lên kiến trúc
D-B02	AI agent viết phần lớn code; 1–3 người PO/BA/review/UAT	Người dùng	Đặc tả không để agent đoán; ranh giới module ép bằng CI; gate người duyệt theo hạng mục (R2)
D-B03	Cloud nội địa Việt Nam, dữ liệu lưu tại Việt Nam	Người dùng	Không phụ thuộc managed service độc quyền; Postgres tự quản trên VM, S3-compatible, Keycloak tự host
D-B05	Codex review code	Người dùng	Gate Codex review bắt buộc trong pipeline mỗi slice
D-B07	NestJS modular monolith, React, PostgreSQL RLS, Redis, Keycloak, Temporal, LiteLLM + Langfuse, PowerSync, outbox	Claude quyết (D-B04)	Xem mục Stack
D-B11	UI tuân thủ mockup, design tokens, component families tài liệu 06	Người dùng	Web/mobile sinh theme từ `design_tokens.json`; visual-regression so với prototype
D-B12	Flutter cho iOS/Android (thay React Native)	Người dùng	Client Dart sinh từ `openapi.json`; contract test bắt buộc backend ↔ app
K1	Modular monolith 25 phân hệ + platform kernel; tách service chỉ khi có số đo tải	Claude quyết	Mục Bản đồ module
K2	PostgreSQL duy nhất cho OLTP, RLS bắt buộc, `SET LOCAL` mỗi transaction, read replica cho BI	Claude quyết	Mục PostgreSQL và RLS
K3	Mọi thay đổi trạng thái qua domain command; GET scaffold là read-model có DTO allowlist	Claude quyết	Mục Command, outbox, inbox, idempotency
K4	Audit bất biến + transactional outbox cùng transaction; consumer idempotent; event có version	Claude quyết	Như trên
K5 (sửa bởi R9)	State machine khai báo trong code (bảng transition + guard + quyền); luồng dài chạy trên Temporal	Claude quyết	Mục Temporal
K6	Object storage S3-compatible, key có tenant prefix, presigned URL ngắn hạn, quét virus trước liên kết	Claude quyết	Mục Tenant và cách ly
K7	Keycloak OIDC, MFA TOTP/WebAuthn, mobile Authorization Code + PKCE	Claude quyết	Mục Danh tính và phiên
K8	Tích hợp ngoài qua port/adapter + mock có contract; trạng thái VERIFIED/PROPOSED/MOCK/MISSING	Claude quyết	Mục Tích hợp
K9	OpenTelemetry có `tenant_id`, không PII; SLO theo D10	Claude quyết	Mục Quan sát; mục SLO và RTO
R1	Mỗi thành phần hạ tầng tự host vào ở slice đầu tiên dùng nó; điều kiện vào = runbook + backup/restore đã thử + cảnh báo	Người dùng (D4)	Mục Hạ tầng theo slice
R2	Mỗi slice khai báo hạng mục bắt buộc người duyệt + giờ review; WIP ≤ 2 slice chờ người	Người dùng (D5)	Gate CI/CD
R4	Quy tắc/mẫu pháp lý là dữ liệu có `legal_basis` + hiệu lực; slice dùng mục [CXN-ARC-01] chưa xác nhận không DONE	Người dùng (D7)	Rule registry trong platform kernel
R5	Request AI gắn `data_classification`; dữ liệu mật/quan trọng/cá nhân chỉ tới model trong nước hoặc tự host	Người dùng (D8)	Mục AI
R6	Tenant = cơ quan chủ quản ký hợp đồng (UBND tỉnh hoặc bộ/ngành)	Người dùng (D9)	Mục Mô hình tenant
R7	Sổ lũy kế tài chính hợp đồng × dòng BOQ × nghiệm thu, khóa hàng + ràng buộc DB + reversal	Người dùng (D10)	Bất biến tiền ở PAY/CTR
R8	DOC: ký PAdES, cấp số bằng incremental update + ký số cơ quan; hai đường ký	Claude quyết theo ủy quyền	Adapter ký số PROPOSED, spike CA ở R0
R9	Temporal là chủ điều phối duy nhất cho luồng dài/phê duyệt; bảng transition domain là guard	Claude quyết theo ủy quyền	Mục Temporal
R10	Màn hình mới được thêm vào prototype đúng tokens/shell	Claude quyết theo ủy quyền	Ngoài phạm vi tài liệu này
R11	Truy vết theo loại: FR chức năng → màn hình + operation + entity + story + test; NFR → control + story + test	Claude quyết theo ủy quyền	`nonfunctional_requirements.json`
A1	Cách ly tenant trên mobile nằm ở sync rules PowerSync	Bằng chứng bắt buộc	Mục PowerSync

ID	Quyết định	Nguồn quyết định	Tác động lên kiến trúc
A3	Import tệp idempotent (hash tệp + khóa nghiệp vụ), đối soát chênh lệch có owner	Bằng chứng bắt buộc	Mục Tích hợp
P1–P3	Index dẫn đầu `tenant_id` cho mọi FK; PeriodSnapshot cho BI; cấp số văn bản bằng khóa hàng sổ	Bằng chứng bắt buộc	Mục PostgreSQL; BI

Trạng thái D01/D02 của baseline 1.3: baseline 1.3 ghi "D01/D02 khóa stack/hạ tầng" trong khi `implementation_decisions.json` vẫn để OPEN. Baseline 1.4 thay câu đó: D01 (stack) được giải bởi D-B07 + D-B12 (NestJS, React, Flutter); D02 (cloud, vùng dữ liệu, IdP, MFA, RLS, quản lý khóa) được giải bởi D-B03 + K2 + K7 + mục Hosting nội địa của tài liệu này. Còn mở: chọn nhà cung cấp cloud nội địa cụ thể và dịch vụ KMS (owner Security/Platform, điều kiện: đáp ứng bảng tiêu chí ở mục Hosting).

Theme & thương hiệu theo tenant — SAS-04

(Cập nhật 1.4 — CR-04-33) Nguồn duy nhất cho quy tắc SAS-04 là `03_Engineering/Tenant_Theme_Specification.html`; mã lỗi review chốt tại `05_modules/SAS.md` (BR-SAS-17). Tóm tắt kiến trúc: chỉ System Admin (control plane, quyền `system.theme.manage`) được ghi; Tenant Admin chỉ đọc bản đã công bố của tenant mình; review gắn actor, tenant, hash nội dung, base version và hạn dùng; publish và rollback là giao dịch nguyên tử tạo phiên bản bất biến mới; lỗi 403/409/422/413; review không còn hợp lệ trả duy nhất `409 REVIEW_INVALID`. Bốn đoạn SAS-04 của baseline 1.3 được chép ở phụ lục.

Ranh giới triển khai và quyết định

(Cập nhật 1.4 — CR-04-34) Stack và hạ tầng được chốt bởi D-B03, D-B07, D-B12 và các mục trên; câu "D01/D02 khóa stack/hạ tầng" của baseline 1.3 không còn là điều kiện mở. Core là modular monolith 25 phân hệ + kernel với các process worker cùng mã nguồn. Control plane System Admin dùng audience/policy riêng, chọn tenant qua target đã xác thực; không cấp BYPASSRLS cho runtime. Hợp đồng phụ thuộc giữa module theo đồ thị ở trên và `Module_Implementation_Contracts.html`; provider adapters có mock trước sandbox. Thứ tự: R0 dựng CI/CD, migration expand-contract, kernel (tenant context, audit, outbox, idempotency), IAM/ADM/SAS tối thiểu, DOC engine, theme/shell trước tính năng nghiệp vụ; R1 lát rộng 25 phân hệ.

(Cập nhật 1.4 — CR-04-35) Tài liệu điều phối: 09_Ke_hoach_trien_khai; 10_Ke_hoach_kiem_thu_va_chuyen_doi; 03_Engineering/nonfunctional_requirements.json; 03_Engineering/Implementation_Backlog.html; 03_Engineering/Test_Case_Catalogue.html; 03_Engineering/Decision_Register.html; 03_Engineering/Implementation_Readiness.html.

Thuật ngữ vai trò

(Cập nhật 1.4 — CR-04-36) Mục mới của baseline 1.4.

Tên chuẩn dùng trong mọi tài liệu, OpenAPI và mã. Tên cũ được liệt kê để thay thế khi sửa tài liệu.

Tên chuẩn	Mã	Phạm vi	Được làm	Không được làm	Tên cũ/biến thể thay thế
System Admin	`system_admin`	Control plane, mọi tenant qua tenant đích	Provisioning tenant, cấu hình thương hiệu (SAS-04), cấp/gia hạn license, phát hành hóa đơn thuê bao	Đọc nội dung nghiệp vụ tenant; bypass RLS	SystemAdmin, Platform admin
Platform Operator	`platform_operator`	Hạ tầng, metadata tối thiểu	Xem health, vận hành, DR	Truy cập nội dung tenant trừ break-glass (SAS-19)	Platform operator, platform support
Tenant Owner	`tenant_owner`	Một tenant (hợp đồng)	Xem hợp đồng, đề nghị đổi gói/license/thương hiệu	Tự cấu hình thương hiệu, tự cấp/gia hạn license	tenant owner
Tenant Admin	`tenant_admin`	Một tenant	Người dùng, cây đơn vị, role grant, workflow, tích hợp	Sửa thương hiệu; đọc hồ sơ mật khi không có grant nghiệp vụ; cấp quyền vượt quyền mình	TenantAdmin, Tenant admin
Billing Admin (FinOps)	`billing_admin`	Một tenant	Xem thuê bao, usage, hóa đơn, chi phí AI/kênh	Đọc đề án, hồ sơ nghiệp vụ	FinOps, Billing admin
AI Admin	`ai_admin`	Một tenant	Publish model/profile/prompt qua review, ngân sách AI	Quyết định kết quả thầu	AI admin
Auditor	`auditor`	Scope được cấp (tenant/cây đơn vị/dự án), chỉ đọc	Đọc, xuất có nguồn, xem lịch sử/audit	Mọi lệnh ghi	Auditor, kiểm toán viên, thanh tra (khi chỉ đọc)

Tên chuẩn	Mã	Phạm vi	Được làm	Không được làm	Tên cũ/biến thể thay thế
Data Protection Officer	`dpo`	Một tenant	Quản lý consent, yêu cầu chủ thể, đánh giá tác động	Sửa dữ liệu nghiệp vụ	(mới, Luật BVDLCN 91/2025)
Data Owner / Data Steward	`data_owner`, `data_steward`	Domain dữ liệu	Duyệt contract, DQ, glossary, merge MDM	—	data owner, steward
Contractor Guest	`contractor_guest`	Hợp đồng của mình	Nộp hồ sơ, xem trạng thái hợp đồng của mình	Xem dự án, vốn, nhà thầu khác	nhà thầu

Vai trò nghiệp vụ (chủ đầu tư, chuyên viên Sở Tài chính, lãnh đạo, kế toán, tổ chuyên gia, văn thư…) được định nghĩa trong đặc tả phân hệ và luôn bị giới hạn bởi tenant boundary, scope grant và classification.

Phụ lục: ánh xạ nội dung baseline 1.3

Danh sách dưới chép nguyên văn mọi đoạn baseline 1.3 đã sửa hoặc bỏ, kèm nơi nội dung hiện nằm. Đoạn không có ở đây được giữ nguyên văn trong thân tài liệu. Mã đoạn `Bnn` đánh số các đoạn không phải tiêu đề của baseline 1.3 theo thứ tự xuất hiện, bắt đầu từ B00.

- **B00** — Sửa (CR-04-01). Nội dung hiện nằm ở: dòng phiên bản đầu tài liệu (Baseline 1.4, thêm đối tượng AI agent viết code).

  > # Hệ Thống Lý Dự Án Đầu Tư Công thiết kế cơ bản Baseline 1.3 | 22/10/2026 | Đối tượng: kiến trúc sư, kỹ thuật trưởng, vận hành và an toàn thông tin.

- **B01** — Sửa (CR-04-03). Nội dung hiện nằm ở: Kiến trúc mục tiêu, đoạn 1 (giữ mọi ý, thêm SAS/System Admin, placement, thương hiệu, vốn, văn bản).

  > **Kiến trúc mục tiêu Phân tách control plane và tenant data plane. Control plane quản lý tenant, domain, gói, subscription, license, entitlement, cấu hình vùng và health. Tenant data plane xử lý dự án, kế hoạch, báo cáo, hồ sơ, thanh toán, vướng mắc, hội thoại và BI. Web/mobile chỉ gọi API/BFF; không truy cập trực tiếp DB, vault hay provider API bằng khóa dài hạn.**

- **B02** — Sửa (CR-04-04). Nội dung hiện nằm ở: Kiến trúc mục tiêu, đoạn 2 (đề xuất trở thành quyết định K1; thêm danh sách process worker).

  > Đề xuất khởi đầu modular monolith cho giao dịch vốn/báo cáo với ranh giới module rõ; tách worker document/OCR, AI gateway, notification và analytics do tải và vòng đời khác. Chưa cần chia mọi CRUD thành microservice. Dùng event/outbox để dễ tách module khi tải và đội vận hành thực sự đòi hỏi. Quyết định này giảm giao dịch phân tán trong kiểm soát số dư và phiên bản.

- **B03** — Sửa (CR-04-05). Nội dung hiện nằm ở: Kiến trúc mục tiêu, đoạn 3 (broker thay bằng outbox relay; thêm luồng import tệp; stack cụ thể).

  > Luồng logic: Web/PWA/Native app → WAF/API gateway → IdP + Tenant resolver + Policy/Entitlement → BFF/API modules → PostgreSQL/Outbox/Object storage. Outbox → broker → analytics projection, notifications, integration, AI jobs. AI worker → retrieval theo ACL → LLM gateway → provider được duyệt. Provider callbacks → webhook gateway → inbox dedupe → worker → domain update.

- **B07** — Sửa (CR-04-11). Nội dung hiện nằm ở: Thành phần và lựa chọn công nghệ, đoạn 1 (React, Flutter D-B12, NestJS D-B07).

  > **Thành phần và lựa chọn công nghệ đề xuất Web: TypeScript/React hoặc nền tảng tương đương có hệ thống design token và accessible components. Mobile: Flutter hoặc React Native sau spike về chữ ký số, camera, biometric, secure storage và offline. Chọn một framework khi chốt đội triển khai; mockup hiện tại không áp đặt**

framework. Core API: .NET hoặc Java theo năng lực đội; dùng một nền tảng chính, không trộn ngôn ngữ không cần thiết.

- **B08** — Sửa (CR-04-12). Nội dung hiện nằm ở: Thành phần và lựa chọn công nghệ, đoạn 2 (broker → outbox relay + inbox; Keycloak).

  PostgreSQL cho transaction/decimal/versioning; object storage S3-compatible cho hồ sơ; Redis cho cache/rate limit/reservation hỗ trợ nhưng ngân sách sổ cái vẫn bền vững; broker có retry/DLQ; data warehouse hoặc column store khi tải BI vượt khả năng read replica/materialized views. Search và vector là projection có thể dựng lại, không là nguồn số tài chính. IdP hỗ trợ OIDC/SAML; chữ ký số và thanh toán qua adapter hợp đồng riêng.

- **B09** — Sửa (CR-04-13). Nội dung hiện nằm ở: Thành phần và lựa chọn công nghệ, đoạn 3 (ADR đề xuất → đã chốt; giữ câu tách interface).

  Các lựa chọn trên là ADR đề xuất, không cam kết phiên bản/library khi chưa kiểm tra môi trường triển khai. Tách interface để thay cloud/private hạ tầng, LLM, kênh gửi và BI renderer.

- **B11** — Sửa (CR-04-18). Nội dung hiện nằm ở: Mô hình miền và nguồn sự thật, đoạn 2 (Acceptance → VolumeAcceptance, thêm CumulativeLedgerEntry và chuỗi 7 phân hệ mới).

  Project → ProcurementPackage → ContractorProposal → DocumentVersion → AnalysisRun → Finding/Evidence → ExpertReview. Contract/Amendment/Acceptance/PaymentRequest/AdvanceLedger liên kết cùng tenant/project. Issue → Assignment/Comment/Attachment/Resolution. MetricDefinition → DatasetVersion → DashboardVersion → QueryContext → ExportJob. NotificationEvent → WorkflowRun → RecipientDecision → DeliveryAttempt. Conversation → ChannelMessage/InternalNote. Tenant → Subscription → UsageMeter/Invoice; Tenant → LicenseRevision → EntitlementSnapshot.

- **B13** — Sửa (CR-04-20). Nội dung hiện nằm ở: Kiến trúc BI, đoạn 1 (outbox/CDC → outbox; staging → projection).

  Kiến trúc BI và drill down Operational DB → outbox/CDC hợp lệ → staging có kiểm tra → facts/dimensions → semantic metrics → query service → dashboard/export. Fact allocation có grain dòng phân bổ theo phiên bản; fact disbursement snapshot theo dự án/kỳ/nguồn; fact treasury transaction theo giao dịch; fact LLM attempt theo request attempt; fact notification theo delivery attempt; fact subscription usage theo meter event.

- **B14** — Sửa (CR-04-21). Nội dung hiện nằm ở: Kiến trúc BI, đoạn 2 (thêm as_of_period, trạng thái kỳ, PeriodSnapshot, read replica P2).

  Dimensions: tenant, thời gian, tổ chức SCD2, dự án, nguồn vốn, chương trình, channel/model/package. BI query service chỉ nhận metric/dimension IDs, filters và snapshot token; compiler tạo truy vấn allowlisted parameterized. Không cho browser gửi SQL vào warehouse. Aggregate table và cache giữ scope/version; lineage từ metric xuống source record và evidence.

- **B22** — Bỏ (trùng lặp SAS-04) (CR-04-33). Nội dung hiện nằm ở: 03_Engineering/Tenant_Theme_Specification.html mục Ma trận quyền; tóm tắt ở mục Theme SAS-04 của tài liệu này.

  Chỉ System Admin được cấu hình thương hiệu cho các tenant: màu sắc, logo, menu, header, footer, tên hệ thống, địa chỉ và thông tin liên hệ. Tenant Admin chỉ được đọc cấu hình đã công bố của tenant mình, không được sửa, lưu nháp, tải logo, tạo review, áp dụng hoặc khôi phục. Các quyền quản trị nội bộ tenant khác không bao gồm quyền cấu hình thương hiệu.

- **B23** — Bỏ (trùng lặp SAS-04) (CR-04-33). Nội dung hiện nằm ở: 03_Engineering/Tenant_Theme_Specification.html mục Trạng thái và luồng, Kiểm tra cấu hình.

  Bản nháp tách biệt theo tenant và không thay đổi giao diện đang dùng. Xem trước web/smartphone trong vùng riêng; bước review hiển thị chênh lệch trước/sau, tenant đích và phiên bản gốc. Xác nhận áp dụng tạo phiên bản bất biến mới. Khôi phục cũng phải review và tạo phiên bản mới, giữ nguyên lịch sử. Kiểm tra trường bắt buộc, email, tệp logo và sáu cặp màu tương phản tối thiểu 4,5:1 trước khi công bố.

- **B24** — Bỏ (trùng lặp SAS-04) (CR-04-33). Nội dung hiện nằm ở: 03_Engineering/Tenant_Theme_Specification.html mục Hợp đồng lỗi và Nghiệm thu; 05_modules/SAS.md BR-SAS-17.

  Server phải xác thực System Admin cho mọi lệnh ghi; không tin vai trò, tenant_id hoặc cờ quyền do trình duyệt gửi. Review gắn actor, tenant, hash nội dung, base version và hạn sử dụng. Kiểm tra lại quyền và phiên bản trong giao

dịch công bố; trả 403 khi thiếu quyền, 409 khi xung đột, 422 khi cấu hình không hợp lệ. Audit ghi người thực hiện, tenant, bản trước/sau, lý do khôi phục và thời điểm; không ghi bí mật vào log.

- **B25** — Bỏ (trùng lặp SAS-04) (CR-04-33). Nội dung hiện nằm ở: 03_Engineering/Tenant_Theme_Specification.html mục Prototype và bằng chứng.

  Prototype SAS-04 dùng localStorage và bộ chọn vai trò mô phỏng để kiểm tra trải nghiệm. Đây không phải hệ thống xác thực hoặc cách ly tenant thật. Chi tiết triển khai và tiêu chí nghiệm thu nằm tại 03_Engineering/Tenant_Theme_Specification.html.

- **B26** — Sửa (CR-04-34). Nội dung hiện nằm ở: Ranh giới triển khai và quyết định, đoạn 1 (D01/D02 được giải bởi D-B03/D-B07/D-B12; thứ tự R0/R1).

  Ranh giới triển khai và quyết định D01/D02 khóa stack/hạ tầng; core modular monolith và worker giữ nguyên. Control plane System Admin dùng audience/policy riêng, chọn tenant qua target đã xác thực; không cấp BYPASSRLS cho runtime. Các module phụ thuộc trong Module_Implementation_Contracts; provider adapters có mock trước sandbox. Xây CI/CD, migration expand-contract, audit/outbox và tenant security trước feature nghiệp vụ.

- **B27** — Sửa (CR-04-35). Nội dung hiện nằm ở: Ranh giới triển khai và quyết định, đoạn 2 (thêm nonfunctional_requirements.json, Implementation_Readiness.html).

  Tài liệu điều phối: 09_Ke_hoach_trien_khai; 10_Ke_hoach_kiem_thu_va_chuyen_doi; 03_Engineering/Implementation_Backlog.html; 03_Engineering/Test_Case_Catalogue.html; 03_Engineering/Decision_Register.html.